Incident Response Playbook and Implementation for Catnip Games SOC

Group- Incident Management

Table of Contents

Section 1: General Incident Response Playbook ***3***
Incident Response Phases 3
Incident Response Workflow 3
Incident Response Decision Tree 4
Severity Classification 4
Containment 5
Investigation 5
Eradication 5
Recovery 5
Post-Incident Review 5

Section 2: Incident Response Playbook Report – Catnip Games SOC ***6***
Catnip Environment Overview 6
Tools Used 6
Roles and Responsibilities 6
Preparation 7
Detection & Analysis 7
Containment, Eradication, Recovery 7
Post-Incident 7
Communication Protocols 7

Section 3: Incident Response Playbook Application ***9***

3.1 Suspicious Login Attempts on Player Accounts **9**
Prerequisites 9
Workflow 10
Checklist 11
Investigation Steps 11

3.2 Bot Activity Detected in Matchmaking Service **13**
Prerequisites 13
Workflow 13
Checklist 14
Investigation Steps 14

3.3 Unauthorised API Access Attempt on Player Data Endpoint **16**
Prerequisites 16
Workflow 16
Checklist 17
Investigation Steps 18

3.4 Malware Detected on Game Server Node GS-07 ..... **20**
Prerequisites 20
Workflow 20
Checklist 21
Investigation Steps 22

3.5 Unusual Data Transfer Volume from Matchmaking DB **24**
Prerequisites 24
Workflow 24
Checklist 25
Investigation Steps 26

Section 1: General Incident Response Playbook

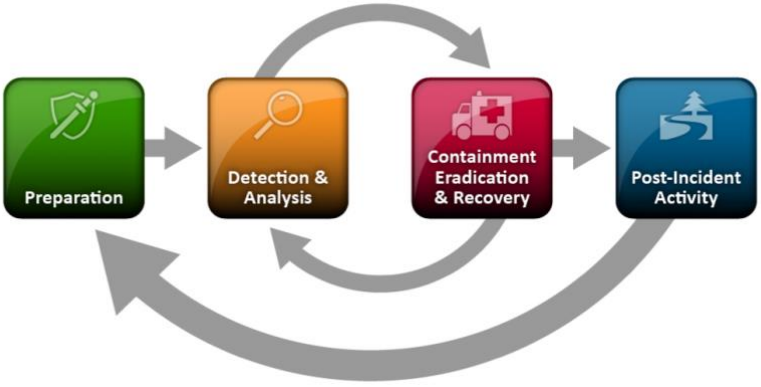
Purpose & Scope

This playbook defines a standardised framework for responding to cybersecurity incidents across environments.

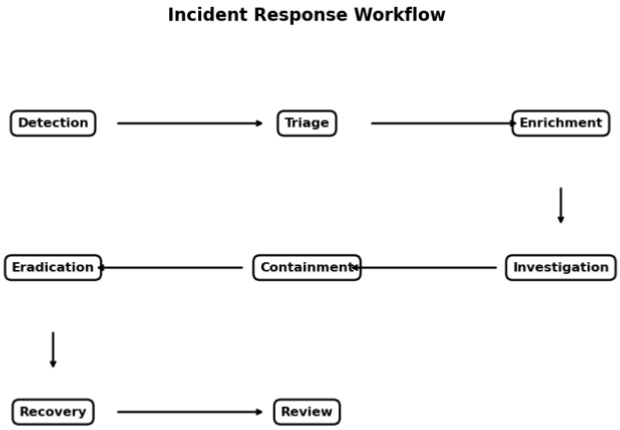
Objectives

- Define severity levels
- Provide structured response process
- Support communication and coordination

Incident Response Phases



Incident Response Workflow

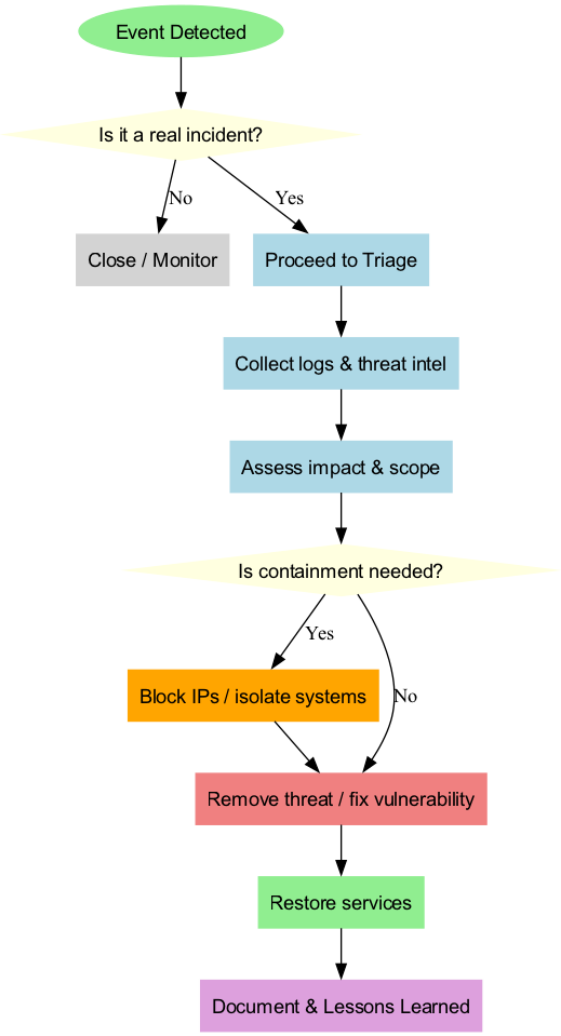


Initial Triage

- Verify alerts
- Assign severity
- Identify observables
- Create case
- Follow decision tree

Incident Response Decision Tree

The decision tree guides analysts through key response decisions, including incident validation, investigation steps, and whether containment is required. This ensures a structured and consistent approach across all incident types.



Severity Classification

Level	Response	Description
Critical	Immediate response	Must be handled immediately, else drastic data breach, game corruption, or similar consequences will occur.
High	Rapid response	Must be handled as soon as possible. Defined as exploited game mechanics, bot activity, social engineering attempts.
Medium	Monitor + investigate	Handled as soon as possible. Defined as general suspicious activity, or activity that has potential to escalate.
Low	Log and monitor	Handled whenever possible. Defined as average, mildly suspicious activity.

Containment

- Immediate actions that contain the incident and prevent escalation.

Investigation

- What sort of review and investigative measures can be taken.
- Any specific information needed to log or identify.

Eradication

- Policies and actions that neutralise and prevent the incident.

Recovery

- Fix damage caused by incident.
- Any future monitoring actions.
- Any confirmation of following actions.

Post-Incident Review

- Take stock of any lasting damage.
- Improve on any protocol.

Section 2: Incident Response Playbook Report – Catnip Games SOC

Catnip Environment Overview

Purpose and Scope

This playbook provides a standardised incident response framework for Cyber Defense Analysts within Catnip Games. It integrates TheHive, MISP, Cortex, and Elasticsearch to detect, analyse, and respond to security incidents affecting game infrastructure and player data.

Objectives

- Outline the severity levels of various active threats (i.e. malware, botting, phishing).
- Develop standardised regulatory framework of (i) documenting these threats, (ii) responding and countering the damage, and (iii) reviewing and improving security protocol.
- Constructing communication pathways and regulation for collaboration between different teams and responsible threat management.

Tools Used

- TheHive
- MISP
- Cortex
- Elasticsearch
- Python

Roles and Responsibilities

Security Operations Team:

- SOC Manager: Oversees incidents, assigns tasks.
- SOC Analysts: Perform triage, investigation, and response.

Preparation

- Deployed MISP, Cortex, Elasticsearch.
- Team training on tools and regulations.

Detection & Analysis

- Automated logging on common MISP events.
- Python scripting and Cortex dashboard for visual alert systems, to be monitored and categorised by SOC Analysts.
- Critical to be handled immediately. High to be handled as soon as possible. Mediums and Lows can be triaged, but after a defined period, to be reassessed on severity.

Containment, Eradication, Recovery

- SOC Manager assigns Analysts tasks and cases via TheHive.
- Strategies to be taken specifically in response to type of attack.

Post-Incident

- SOC Manager hosts a review with Analysts involved, going through incident documentation and timeline.
- Improvements to process to be implemented. Patch update if needed.

Communication Protocols

Internal: Analysts standardise alert systems and incident logging. Analysts categorise threats to report to TheHive, SOC Manager monitors TheHive to assign cases. Critical and High threats are reported immediately to SOC Manager, via in-person or phone. SOC Manager will relay tasks.

External: During resolution or post-incident, Analysts may confirm necessary communication to other teams or the playerbase. SOC Manager will communicate with other team managers. SOC Manager and Analysts will report to PR Team for communication to playerbase.

Section 3: Incident Response Playbook Application

This section demonstrates how the incident response playbook is applied to specific cybersecurity incidents within the Catnip Games environment. Each entry follows a standardised structure: prerequisites, workflow, checklist, and detailed investigation steps.

Important Note on SIEM Integration

The playbook entries below reference a SIEM as the detection and alerting layer. This reflects industry best practice for a production SOC environment. In the Catnip Games lab environment, detection is performed using the existing toolset (TheHive, MISP, Cortex, and Elasticsearch). Where a SIEM is referenced, it should be understood as the recommended detection source in a fully operational SOC, and can be substituted with whichever SIEM or log management platform is deployed in the target environment.

Additionally, case templates in TheHive have been pre-configured for each attack type. Severity classification, TLP/PAP markings, observables, and TTPs are automatically populated when a case is created from the relevant template. These fields are therefore not repeated in the individual playbook entries below.

3.1 Suspicious Login Attempts on Player Accounts

Attack Type: Credential Stuffing / Phishing

Suspicious Login Attempts on Player Accounts	
Severity **HIGH**	Target Response Time **≤ 4 hours (initial response), ≤ 24 hours (containment)**

Prerequisites

The following conditions must be met before initiating this investigation:

- Authentication logging enabled on all player-facing services (login attempts, failed attempts, geo-location, user-agent).
- SIEM configured with rules for brute-force and credential stuffing detection (e.g., threshold-based alerts for failed logins per account or per source IP).
- Cortex integrated with TheHive, with AbuseIPDB, VirusTotal, and Shodan analysers enabled and accessible directly from case observables.
- MISP instance populated with known credential-stuffing botnet IOCs and phishing infrastructure indicators.
- SOC Analyst has read/write access to TheHive for case and task management.
- Perimeter firewall admin credentials available for IP blocking actions.
- Player notification template pre-approved by PR team for credential reset communications.

Workflow

The following workflow outlines the logical sequence of response phases for this incident:

#	Phase	Action
1	**Detection**	Alert triggered by SIEM for anomalous login volume or failed authentication threshold breach.
2	**Triage**	Verify alert legitimacy, create TheHive case from template (auto-populates severity, TLP, PAP, TTPs).
3	**Enrichment**	Run Cortex analysers on suspicious source IPs directly from TheHive observables and review reports in-platform.
4	**Investigation**	Examine affected player accounts, determine scope, correlate IOCs in MISP.
5	**Containment**	Block malicious IPs at perimeter firewall, invalidate compromised sessions, force credential resets.
6	**Eradication**	Remove attacker sessions, address authentication weaknesses exploited.
7	**Recovery**	Notify affected players, restore account access, recommend MFA enrolment.

8	**Review**	Document lessons learned, update detection rules, close case in TheHive.

Checklist

Use this checklist to track task completion. Each item corresponds to a task in the TheHive case:

1. ☐ Verify alert source and confirm suspicious IPs.
2. ☐ Investigate affected player accounts for unauthorised access.
3. ☐ Correlate IOCs in MISP against known credential-stuffing campaigns.
4. ☐ Run Cortex analysers on suspicious IP observables in TheHive and review analyser reports.
5. ☐ Block suspicious IPs at perimeter firewall.
6. ☐ Notify affected players and reset credentials.
7. ☐ Post-incident review and close case in TheHive.

Investigation Steps

Detailed step-by-step guidance for this investigation:

1. Review the SIEM alert details: examine the source IPs triggering the alert, the volume of failed login attempts, the targeted player accounts, and the geographic distribution of the login attempts. Identify whether the pattern indicates credential stuffing (many accounts, few attempts each) or brute force (few accounts, many attempts).
2. In TheHive, create a new case from the Phishing/Credential Stuffing template. The template will auto-populate severity, TLP, PAP, observables, and TTPs. Add any additional observables specific to this incident including suspicious source IPs, targeted account usernames, timestamps, and user-agent strings.
3. From the TheHive case, select each suspicious source IP observable and run the integrated Cortex analysers. Run AbuseIPDB to check for prior abuse reports, VirusTotal for threat intelligence associations, and Shodan to identify whether the IPs belong to known proxy services, VPNs, or botnets. Review all analyser reports directly within TheHive.

4. Cross-reference the identified IOCs (IPs, user-agents, any associated domains) in MISP. Look for matches against existing events related to credential-stuffing botnets, phishing campaigns, or compromised credential databases.
5. Investigate the affected player accounts: determine how many accounts had successful unauthorised logins, whether any in-game assets or payment methods were accessed, and whether account recovery emails or phone numbers were changed by the attacker.
6. Implement containment by blocking all confirmed malicious source IPs at the perimeter firewall. Invalidate any active sessions from compromised accounts. Force a credential reset on all accounts that experienced successful unauthorised access.
7. Coordinate with the PR team to issue player notifications explaining the incident and instructing affected users to reset their passwords. Recommend enabling two-factor authentication where available.
8. Conduct a post-incident review: document the full timeline, the number of affected accounts, the attack vector, and the effectiveness of the detection rules. Identify improvements such as stricter rate-limiting on login endpoints, enhanced geo-blocking, or mandatory MFA rollout. Update SIEM rules as needed and close the case in TheHive.

3.2 Bot Activity Detected in Matchmaking Service

Attack Type: Bot Attack / Automated Abuse

Bot Activity Detected in Matchmaking Service	
Severity **MEDIUM**	Target Response Time **≤ 8 hours (initial response), ≤ 48 hours (containment)**

Prerequisites

The following conditions must be met before initiating this investigation:

- Matchmaking service logging enabled capturing session metadata, player behaviour patterns, input timing, and API call frequency.
- SIEM or Elasticsearch configured with detection rules for anomalous matchmaking patterns (e.g., inhuman reaction times, repetitive actions, high API call rates from single accounts).
- Cortex integrated with TheHive, with IP reputation analysers (AbuseIPDB, VirusTotal) accessible directly from case observables.
- MISP instance containing indicators related to known gaming bot frameworks and automation tools.
- SOC Analyst has read/write access to TheHive.
- Game operations team contact available for account suspension actions.
- Rate-limiting and CAPTCHA deployment capability on matchmaking API endpoints.

Workflow

The following workflow outlines the logical sequence of response phases for this incident:

#	Phase	Action
1	**Detection**	Anomalous matchmaking patterns flagged by monitoring or Elasticsearch queries.

2	**Triage**	Confirm bot behaviour, create TheHive case from template (auto-populates metadata).
3	**Enrichment**	Run Cortex analysers on source IPs directly from TheHive observables and review reports in-platform.
4	**Investigation**	Map full bot network scope, correlate IOCs in MISP.
5	**Containment**	Block bot IPs at network level, suspend identified bot accounts.
6	**Eradication**	Deploy rate limiting and CAPTCHA on targeted endpoints.
7	**Recovery**	Restore fair matchmaking conditions, monitor for recurrence.
8	**Review**	Document findings, propose anti-bot improvements, close case.

Checklist

Use this checklist to track task completion. Each item corresponds to a task in the TheHive case:

1. ☐ Confirm bot activity and identify affected services.
2. ☐ Identify bot source IPs and account patterns.
3. ☐ Run Cortex analysers on suspicious IP observables in TheHive and review analyser reports.
4. ☐ Correlate IOCs in MISP against known bot frameworks.
5. ☐ Block bot IPs and suspend associated accounts.
6. ☐ Implement rate limiting and CAPTCHA on affected endpoints.
7. ☐ Post-incident review and close case in TheHive.

Investigation Steps

Detailed step-by-step guidance for this investigation:

1. Examine the monitoring alerts that flagged the anomalous matchmaking activity. Look for patterns such as: accounts with inhuman reaction speeds, repetitive identical match actions, abnormally high win rates concentrated in specific game modes, or API call frequencies far exceeding normal player behaviour.

2. Create a TheHive case from the Bot Attack template. The template will auto-populate severity, TLP, PAP, and TTPs. Add incident-specific observables including suspected bot account IDs, their source IPs, session timestamps, and any common characteristics (e.g., similar account creation dates, naming patterns, or device fingerprints).
3. From the TheHive case, select the source IP observables associated with bot accounts and run the integrated Cortex analysers (AbuseIPDB, VirusTotal). Review the analyser reports in TheHive to determine whether these IPs belong to data centres, residential proxies, or VPN services commonly used by bot operators.
4. Search MISP for indicators matching the identified IPs, account patterns, or user-agent strings. Look for correlations with known gaming bot frameworks, automation tools, or previously reported bot campaigns targeting similar game genres.
5. Map the full scope of the bot network: identify all accounts exhibiting bot-like behaviour, the total number of affected matchmaking sessions, and any economic impact on the in-game economy (e.g., currency farming, item duplication, rank boosting). Assess whether legitimate players were negatively affected by unfair matchmaking.
6. Implement containment by blocking all confirmed bot source IPs at the network level. Work with the game operations team to suspend or ban all identified bot accounts. Invalidate any in-game gains obtained through bot activity where possible.
7. Deploy rate limiting on the matchmaking API endpoints to throttle excessive request rates. Implement CAPTCHA challenges on endpoints that bots were targeting. Consider adding behavioural analysis checks (e.g., input timing variance, mouse movement patterns) to the matchmaking flow.
8. Conduct a post-incident review: document the scale of the bot operation, the detection timeline, and propose improvements. These may include enhanced behavioural detection rules, integration of anti-bot middleware, and regular audits of matchmaking fairness metrics. Close the case in TheHive.

3.3 Unauthorised API Access Attempt on Player Data Endpoint

Attack Type: API Abuse / Data Exfiltration Attempt

Unauthorised API Access Attempt on Player Data Endpoint	
Severity **CRITICAL**	Target Response Time **≤ 1 hour (initial response), ≤ 4 hours (containment)**

Prerequisites

The following conditions must be met before initiating this investigation:

- API gateway logging enabled capturing all requests to player data endpoints (source IP, API key used, request parameters, response codes, payload sizes).
- SIEM or Elasticsearch alerts configured for anomalous API access patterns (e.g., unauthorised HTTP methods, unusual query parameters, excessive data retrieval, access from unexpected IP ranges).
- Cortex integrated with TheHive, with IP and URL reputation analysers accessible directly from case observables.
- MISP instance containing threat intelligence on API abuse campaigns and data exfiltration techniques.
- SOC Analyst has read/write access to TheHive and access to API key management console for rotation.
- Firewall and WAF admin access available for IP blocking and rule updates.
- Data breach notification procedure documented, including GDPR Article 33 timeline requirements (72-hour notification to ICO).

Workflow

The following workflow outlines the logical sequence of response phases for this incident:

#	Phase	Action

1	**Detection**	Anomalous API access patterns trigger SIEM alert or Elasticsearch query match.
2	**Triage**	Confirm unauthorised access, create TheHive case from template (auto-populates metadata).
3	**Enrichment**	Run Cortex analysers on source IPs and URLs from TheHive observables, correlate indicators in MISP.
4	**Investigation**	Determine whether data was accessed, identify the attack method and scope.
5	**Containment**	Block attacker IPs, rotate compromised API keys, restrict endpoint access.
6	**Eradication**	Patch the API vulnerability, harden endpoint security controls.
7	**Recovery**	Assess GDPR breach notification obligations, notify affected players if required.
8	**Review**	Implement API security improvements, close case in TheHive.

Checklist

Use this checklist to track task completion. Each item corresponds to a task in the TheHive case:

1. ☐ Confirm unauthorised access attempt and identify the targeted endpoint.
2. ☐ Identify source IPs and attack pattern.
3. ☐ Run Cortex analysers on suspicious IP and URL observables in TheHive and review analyser reports.
4. ☐ Correlate IOCs in MISP.
5. ☐ Assess if player data was successfully accessed or exfiltrated.
6. ☐ Block attacker IPs and rotate compromised API keys.
7. ☐ Assess data breach notification requirement under GDPR.
8. ☐ Harden API security on affected endpoints.
9. ☐ Post-incident review and close case in TheHive.

Investigation Steps

Detailed step-by-step guidance for this investigation:

1. Review the alert details from the API gateway logs. Identify which player data endpoint was targeted, the HTTP methods used (GET, POST, etc.), the source IPs, the API keys involved, and the volume of data requested or returned. Determine whether the requests used valid but compromised API credentials or attempted to exploit an authentication bypass.
2. Create a TheHive case from the API Abuse template. The template will auto-populate severity, TLP, PAP, observables, and TTPs. Add incident-specific observables: source IPs, API keys used, targeted endpoints, request timestamps, and any unusual query parameters or headers.
3. From the TheHive case, select the source IP and URL observables and run the integrated Cortex analysers. Check AbuseIPDB for prior reports, VirusTotal for threat associations, and Shodan for infrastructure reconnaissance data. Review all analyser reports directly within TheHive.
4. Search MISP for correlations with the identified IOCs. Look for matches with known API abuse campaigns, data scraping operations, or threat actors targeting gaming platforms.
5. Conduct a thorough investigation to determine whether player data was successfully accessed. Review API response logs to establish the exact volume and type of data returned to the attacker (e.g., usernames, email addresses, payment information, gameplay data). Cross-reference with database access logs if available.
6. Implement immediate containment: block all confirmed attacker IPs at the WAF and perimeter firewall. Rotate all API keys that were used in the unauthorised requests. If the attack exploited a specific API vulnerability, temporarily restrict access to the affected endpoint until a fix is deployed.
7. Assess whether the incident constitutes a personal data breach under GDPR. If player personal data (names, emails, IPs, payment details) was confirmed or likely accessed, initiate the 72-hour notification process to the ICO as required by Article 33. Document the assessment rationale regardless of outcome.
8. Harden API security: implement stricter authentication and authorisation checks on the affected endpoints, add request rate limiting, deploy input validation to prevent parameter manipulation, and review API key issuance and rotation policies.

9. Conduct a post-incident review: document the attack timeline, the root cause (e.g., weak API authentication, missing rate limiting, insecure direct object references), and the data exposure scope. Propose improvements including API security testing as part of the development lifecycle, WAF rule enhancements, and improved monitoring for data exfiltration patterns. Close the case in TheHive.

3.4 Malware Detected on Game Server Node GS-07

Attack Type: Malware Infection

Malware Detected on Game Server Node GS-07	
Severity **CRITICAL**	Target Response Time **≤ 1 hour (initial response), ≤ 4 hours (containment)**

Prerequisites

The following conditions must be met before initiating this investigation:

- Endpoint detection and response (EDR) or antivirus solution deployed on all game server nodes with real-time alerting to the SIEM.
- SIEM configured with file integrity monitoring (FIM) rules for critical game server directories and system binaries.
- Cortex integrated with TheHive, with file hash analysers (VirusTotal, YARA rule matching) and IP reputation analysers accessible directly from case observables.
- MISP populated with malware IOCs (file hashes, C2 domains, known exploit signatures) relevant to the gaming sector.
- SOC Analyst has read/write access to TheHive and sufficient server access for forensic evidence collection (or access to a forensic imaging tool).
- Network segmentation in place allowing isolation of individual game server nodes without full service outage.
- Backup and restore procedures documented for game server nodes, including verified clean backup availability.
- Vulnerability management records available to identify the patch status of affected servers.

Workflow

The following workflow outlines the logical sequence of response phases for this incident:

#	Phase	Action
1	**Detection**	EDR or SIEM file integrity monitoring alert triggers on game server GS-07.
2	**Triage**	Confirm malware presence, create TheHive case from template (auto-populates metadata).
3	**Isolation**	Immediately isolate GS-07 from the network to prevent lateral movement.
4	**Forensics**	Collect and preserve forensic evidence (memory dump, disk image, logs).
5	**Analysis**	Analyse malware sample, extract IOCs (hashes, C2 addresses, persistence mechanisms).
6	**Enrichment**	Run Cortex analysers on extracted IOCs from TheHive observables, correlate in MISP.
7	**Lateral Check**	Scan all other game servers for matching indicators of compromise.
8	**Eradication**	Remove malware, patch exploited vulnerability, restore from clean backup.
9	**Review**	Document findings, improve defences, close case in TheHive.

Checklist

Use this checklist to track task completion. Each item corresponds to a task in the TheHive case:

1. ☐ Confirm malware detection and identify the affected server.
2. ☐ Isolate affected server from the network immediately.
3. ☐ Collect and preserve forensic evidence (memory dump, disk image, logs).
4. ☐ Analyse malware sample and extract IOCs (file hashes, C2 addresses, mutex names).
5. ☐ Run Cortex analysers on extracted IOC observables in TheHive and review analyser reports.
6. ☐ Correlate IOCs in MISP against known malware families.
7. ☐ Scan all other game servers for indicators of compromise.

8. ☐ Eradicate malware and restore affected server from clean backup.
9. ☐ Patch the vulnerability used for initial access.
10. ☐ Post-incident review and close case in TheHive.

Investigation Steps

Detailed step-by-step guidance for this investigation:

1. Review the EDR or SIEM file integrity monitoring alert for GS-07. Identify the specific file(s) flagged, their location on the server, the file hashes (MD5, SHA-1, SHA-256), and the timestamp of detection. Determine whether the alert was triggered by a new file creation, a modification to an existing binary, or anomalous process behaviour.
2. Create a TheHive case from the Malware template. The template will auto-populate severity, TLP, PAP, and TTPs. Add incident-specific observables including file hashes, file paths, process names, and any network connections observed from the suspicious process.
3. Immediately isolate GS-07 from the network by applying firewall rules or VLAN changes that prevent all inbound and outbound traffic except for forensic collection access. This prevents potential lateral movement and disrupts command-and-control communication.
4. Collect forensic evidence before any remediation: capture a full memory dump using a tool such as LiME or WinPmem, take a disk image or snapshot of the affected server, and preserve all relevant logs (system logs, application logs, network connection logs). Maintain chain of custody documentation.
5. Analyse the malware sample in a sandboxed environment. Identify the malware family, its capabilities (e.g., backdoor, cryptominer, data stealer, ransomware), persistence mechanisms (e.g., cron jobs, systemd services, registry keys), and any command-and-control infrastructure it communicates with. Extract all IOCs: file hashes, C2 domains/IPs, mutex names, dropped files, and registry modifications.
6. From the TheHive case, add all extracted IOCs as observables (file hashes, C2 IPs, C2 domains) and run the integrated Cortex analysers on each. Submit file hashes to VirusTotal for multi-engine detection results, check C2 IPs and domains against AbuseIPDB and Shodan, and run any available YARA rules. Review all analyser reports directly within TheHive.

7. Correlate all IOCs in MISP. Identify whether this malware matches a known campaign, whether other organisations have reported similar infections, and whether additional IOCs from related MISP events should be added to the scanning scope.
8. Using the IOCs extracted from the malware analysis, scan all other game server nodes for indicators of compromise. Check for the presence of matching file hashes, network connections to identified C2 infrastructure, and similar persistence mechanisms. Prioritise servers in the same network segment as GS-07.
9. Eradicate the malware from GS-07: if the server can be safely rebuilt, restore from the most recent verified clean backup. If restoration is not immediately possible, manually remove all identified malware artefacts, persistence mechanisms, and attacker-created accounts. Verify the server is clean by running a full scan with updated signatures.
10. Identify and patch the vulnerability that allowed initial access. Review how the malware was introduced (e.g., unpatched software vulnerability, compromised credentials, supply chain compromise) and apply the appropriate fix. Update firewall rules and access controls to prevent similar intrusions.
11. Conduct a post-incident review: document the full attack timeline from initial compromise to detection, the malware capabilities, the root cause, and the scope of impact. Propose improvements including reducing detection latency (enhanced FIM rules, more frequent scans), network segmentation hardening, and a vulnerability patching cadence review. Close the case in TheHive.

3.5 Unusual Data Transfer Volume from Matchmaking DB

Attack Type: Data Exfiltration

Unusual Data Transfer Volume from Matchmaking DB	
Severity **HIGH**	Target Response Time **≤ 4 hours (initial response), ≤ 24 hours (containment)**

Prerequisites

The following conditions must be met before initiating this investigation:

- Database activity monitoring (DAM) or audit logging enabled on the matchmaking database, capturing query volumes, data transfer sizes, source connections, and query types.
- SIEM or Elasticsearch alerts configured for anomalous database access patterns (e.g., unusually large SELECT queries, bulk data exports, connections from non-application source IPs).
- Network monitoring with data loss prevention (DLP) capabilities, or at minimum, NetFlow/traffic volume baselines for database server interfaces.
- Cortex integrated with TheHive, with IP and domain reputation analysers accessible directly from case observables.
- MISP populated with indicators related to data exfiltration techniques and known threat actor infrastructure.
- SOC Analyst has TheHive access, database audit log access, and network traffic capture capability.
- GDPR data breach response procedure documented, with ICO notification templates and DPO contact details available.
- Player communication templates pre-approved for data breach scenarios.

Workflow

The following workflow outlines the logical sequence of response phases for this incident:

#	Phase	Action
1	**Detection**	Anomalous outbound data volume flagged by monitoring or SIEM alert.
2	**Triage**	Confirm data exfiltration activity, create TheHive case from template (auto-populates metadata).
3	**Enrichment**	Run Cortex analysers on destination IPs and domains from TheHive observables and review reports in-platform.
4	**Investigation**	Identify the data scope, exfiltration method, and attacker infrastructure.
5	**Containment**	Block exfiltration destination, restrict compromised DB access, isolate if needed.
6	**Assessment**	Determine full data exposure scope and GDPR notification obligations.
7	**Recovery**	Harden database and network controls, notify players if required.
8	**Review**	Improve DLP and monitoring capabilities, close case in TheHive.

Checklist

Use this checklist to track task completion. Each item corresponds to a task in the TheHive case:

1. ☐ Confirm unusual data transfer and identify source.
2. ☐ Identify what data was transferred.
3. ☐ Identify the exfiltration method and attacker infrastructure.
4. ☐ Run Cortex analysers on destination IP and domain observables in TheHive and review analyser reports.
5. ☐ Correlate IOCs in MISP.
6. ☐ Contain the exfiltration immediately (block destination, restrict DB access).
7. ☐ Assess full scope of data exposure.
8. ☐ Assess GDPR and data breach notification requirement.

9. ☐ Notify affected players if required.
10. ☐ Harden database and network security controls.
11. ☐ Post-incident review and close case in TheHive.

Investigation Steps

Detailed step-by-step guidance for this investigation:

1. Review the monitoring alert that flagged the unusual data transfer. Examine the database audit logs to identify the specific queries or operations that generated the anomalous outbound data volume. Determine the source of the database connection (application server, direct connection, compromised account) and the destination IP or domain the data was sent to.
2. Create a TheHive case from the Data Exfiltration template. The template will auto-populate severity, TLP, PAP, and TTPs. Add incident-specific observables: source database connection details, destination IPs and domains, the volume of data transferred, timestamps, and the database user account used.
3. Identify precisely what data was transferred. Analyse the database queries to determine which tables and fields were accessed (e.g., player usernames, email addresses, hashed passwords, payment records, IP addresses, gameplay data). Quantify the number of records affected.
4. Determine the exfiltration method: was data pulled via SQL injection, compromised application credentials, a rogue database user, or a compromised application server acting as a proxy? Identify the full attacker infrastructure including any staging servers, external storage endpoints, or encrypted tunnels used.
5. From the TheHive case, select the destination IP and domain observables and run the integrated Cortex analysers. Check AbuseIPDB for abuse history, VirusTotal for threat associations, and Shodan for infrastructure details. Review the analyser reports in TheHive to identify whether the destination infrastructure is associated with known threat actors.
6. Correlate all identified IOCs in MISP. Search for matches with known data exfiltration campaigns, threat actor infrastructure, or similar incidents reported by other organisations in the gaming sector.

7. Implement immediate containment: block all identified exfiltration destination IPs and domains at the perimeter firewall. Restrict the compromised database user account. If the exfiltration path used a compromised application server, isolate that server. If direct database access was used, restrict database connectivity to only authorised application servers.
8. Assess the full scope of data exposure: determine the total number of player records accessed, the sensitivity classification of the data (personal data under GDPR includes names, emails, IPs, payment details), and whether the data was encrypted in transit or at rest.
9. Evaluate GDPR notification obligations: if the breach involves personal data and poses a risk to the rights and freedoms of data subjects, the ICO must be notified within 72 hours of becoming aware of the breach (GDPR Article 33). If the risk is high, affected players must also be notified directly (Article 34). Document this assessment and decision.
10. If player notification is required, coordinate with the PR team and DPO to issue communications explaining the nature of the breach, the data involved, and recommended protective actions (e.g., password changes, monitoring for suspicious activity).
11. Harden database and network security controls: implement stricter database access controls (principle of least privilege), enable query-level monitoring with alerting for bulk data access, deploy network-level DLP to detect large outbound data transfers, and review application-to-database authentication mechanisms.
12. Conduct a post-incident review: document the attack timeline, the root cause, the volume and type of data exfiltrated, and the effectiveness of detection. Propose improvements including database activity monitoring enhancements, network traffic baselining, DLP deployment, and regular access control audits. Close the case in TheHive.